

IT Vendor Risk Assessment Report

Service: ServiceName

Generated: 2026-06-20 16:35 | Classification: INTERNAL CONFIDENTIAL | Framework: Murdoch University Risk Management Framework

Assessment scope: Murdoch University internal policy documents and HECVAT template only. No external frameworks (NIST, ISO, GDPR etc.) applied. Risk scored via Murdoch RMF likelihood × impact matrix on assessed controls only. Controls marked INSUFFICIENT_EVIDENCE reflect policy knowledge-base coverage gaps, not vendor compliance status.

1. Executive Summary

Metric	Value
Total Controls	126
Assessed (policy match)	112
Insufficient Evidence	14
Coverage	88.9%
Compliant	17
Partial	74
Gaps	21
Extreme Risks	3
High Risks	4
■■ RMF Score (assessed)	3.28
■■ Overall Risk Band	MEDIUM

2. Murdoch RMF Risk Legend

RMF Level	Likelihood × Impact	Action
EXTREME	High L × High I	Immediate action required
HIGH	High L × Med I	Senior management attention
MEDIUM	Med L × Med I	Management responsibility
MINOR	Low L × Med I	Monitor and review
LOW	Low L × Low I	Routine procedures

3. Risk by Section (Assessed Controls Only)

Section	Avg RMF Score	Band
AI/ML Data Separation	3.83	HIGH

Data Security	3.75	HIGH
Access Control	3.67	HIGH
Firewall & IDS/IPS	3.6	HIGH
AI Policy	3.6	HIGH
Data Center	3.5	HIGH
Vulnerability Management	3.5	HIGH
LLM Privileges	3.33	MEDIUM
Application Security	3.3	MEDIUM
AI Governance	3.2	MEDIUM
Change Management	3.15	MEDIUM
Third-Party Management	3.0	MEDIUM
Policies, Processes & Procedures	2.86	MEDIUM
AI Security	2.67	MEDIUM
IT Accessibility	2.55	MEDIUM
Operational & Emerging Tech	2.25	MINOR

■ EXTREME Risks — Immediate Action Required

- [DATA-04] Vendor did not provide evidence to corroborate their claim. Murdoch University policy (ICT Security Standard 1.pdf, Section 6) references the ACSC Essential Eight Maturity Model which implicitly requi
- [AIML-01] Vendor's response contradicts Murdoch University's policy requiring separation of ML training data from the solution. This poses a significant risk to data integrity and model bias, potentially leadin
- [AIML-02] Vendor does not authenticate and verify ML model feedback, failing to meet Murdoch University's requirement for ensuring research obligations request a user account (i.e. MAIS other) from an authorise

■ HIGH Risks — Senior Management Attention

- [DCTR-14] Murdoch University policy (Policy 2 and Policy 5) mandates MFA for all authentications unless technically restricted and approved. The vendor's response directly contradicts this requirement. Failure
- [OPEM-03] The vendor's refusal to provide required architectural diagrams and data communication descriptions directly contradicts Murdoch University's policy requirements (ICT Security Standard 1.pdf) regardin
- [AIPL-01] The vendor provided no evidence to support their claim. Murdoch University policy (ICT Security Policy 1.pdf) requires demonstrable implementation and posting of AI risk management practices. Without
- [AIML-05] The vendor's response directly contradicts Murdoch University's policy (Policy 10.4.3 and 10.4.5) which mandates that IT resources must be adjusted accordingly and privileged users must not modify pro

4. Detailed Findings

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-05	IT Accessibility	GAP	PARTIAL	PARTIAL	MINOR	3	2	The vendor provided a link to an accessibility page but did not provide a formal accessibility statement (VPAT) or equivalent document as required by Murdoch University's policy. While the link suggests some consideration of accessibility, it doesn't demonstrate full compliance with the requirement for a documented commitment.	4.1.3. Applied for and submitted through the Murdoch Support Service Portal;	Request a VPAT or equivalent documentation from the vendor to verify their accessibility practices and ensure alignment with Murdoch University's requirements.
ITAC-07	IT Accessibility	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor has stated agreement but provided no evidence of how they will meet WCAG 2.1 AA standards or integrate this into their contractual obligations. Murdoch University's policy (Policy 2) requires adherence to international and industry-specific compliance standards such as ISO 27001, which doesn't explicitly cover accessibility standards like WCAG. The vendor needs to demonstrate a concrete plan.		Require the vendor to provide detailed documentation outlining their approach to meeting WCAG 2.1 AA requirements and how this will be incorporated into the contract. Request evidence of ongoing monitoring and testing for accessibility compliance.
ITAC-08	IT Accessibility	GAP	NOT_ASSESSED	INSUFFICIENT_EVIDENCE	HIGH	4	3	The vendor provided no evidence to support their claim of WCAG 2.1 AA compliance. Murdoch University requires adherence to international and industry-specific standards like ISO 27001 (Policy 2) and specifically references Digital Media Disposal Standard (Policy 3). Without supporting documentation, it's impossible to assess whether the solution meets these requirements.		Request detailed evidence of WCAG 2.1 AA compliance from the vendor, including test results or a documented audit process.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-09	IT Accessibility	GAP	PARTIAL	PARTIAL	MEDIUM	4	2	The vendor did not provide any evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf, Section 7) requires timely information about technical vulnerabilities and a risk assessment. Without supporting documentation, it's impossible to verify the effectiveness of their process.	7.1 Information Technology Services will obtain timely information about technical vulnerabilities for all systems at Murdoch University, assess the University's exposure to identified vulnerabilities and perform a risk assessment.	Request detailed documentation outlining the vendor's accessibility issue reporting and tracking process, including specific tools used, frequency of reviews, and metrics for measuring effectiveness.
ITAC-11	IT Accessibility	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor did not provide any evidence to support their claim of an audit. Murdoch University policy does not require specific documentation of the audit process or expert qualifications. Therefore, we cannot assess compliance.		Request supporting documentation from the vendor detailing the scope, methodology, and credentials of the third-party expert who conducted the audit.
ITAC-12	IT Accessibility	GAP	NOT_ASSESSED	GAP	MINOR	3	2	The vendor provided no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf) references the ACSC Essential Eight Maturity Model which implicitly requires a documented process for vulnerability management and accessibility testing. Without supporting documentation or demonstrable implementation, we cannot assess compliance.		Request detailed documentation of the vendor's accessibility verification process, including specific tools used, test methodologies, and results. Obtain evidence of ongoing monitoring and remediation activities.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-13	IT Accessibility	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim of adopting a technical or legal standard. Murdoch University requires adherence to ISO 27001 as per Policy 1. Without demonstrable compliance with an internationally recognized standard, the risk remains uncertain.	systems and services used by Murdoch University must meet a set of international and industry-specific compliance standards, such as ISO 27001 for assurance that the specified requirements are met.	Request specific details regarding the adopted standard and supporting documentation (e.g., certification reports) before proceeding.
ITAC-14	IT Accessibility	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor provided no evidence of a roadmap or delivery timelines. Murdoch University policy (ICT Security Standard 1.pdf, Section 7.1) requires documented authorization and the use of a specific form (Confidential & Operational Data Access Request Form) for all requests. Without these elements, compliance is not demonstrated.		Request detailed accessibility roadmap with specific delivery timelines from the vendor before proceeding.
ITAC-15	IT Accessibility	PARTIAL	COMPLIANT	COMPLIANT	MINOR	3	2	While the vendor states they expect staff to maintain skills, Murdoch University policy (Policy 5: ICT Security Policy 1.pdf) mandates that access levels must be 'No higher than required to perform the work applying the principle of least privileged in all cases.' The vendor's response doesn't explicitly address how they ensure this ongoing training and skill maintenance occurs, leaving a potential gap.	4.1.1. No higher than required to perform the work applying the principle of least privileged in all cases	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
ITAC-16	IT Accessibility	PARTIAL	COMPLIANT	PARTIAL	MINOR	3	2	While the vendor states they have documented processes, no evidence was provided to corroborate this claim. Murdoch University requires documented procedures and policies for accessibility implementation (Policy 4.1.1). The lack of supporting documentation raises concerns about the thoroughness and effectiveness of their approach.	4.1.1. No higher that required to perform the work applying the principle of least privileged in all cases	Request detailed documentation outlining these processes and procedures, including specific techniques and tools used. Verify alignment with Murdoch's requirements for accessible design.
ITAC-17	IT Accessibility	COMPLIANT	PARTIAL	COMPLIANT	MINOR	3	2	While the vendor states compliance with keyboard accessibility, no evidence was provided to corroborate this claim. Murdoch University policy (Policy 1: ICT Security Standard 1.pdf) requires authentication for network services and local device access, but doesn't explicitly address keyboard-only operation. Therefore, we cannot definitively assess alignment.		
ITAC-18	IT Accessibility	GAP	COMPLIANT	PARTIAL	MINOR	3	2	The vendor's response does not explicitly address whether their product *could* be adapted to provide accessibility features through alternative interfaces. While they state they don't currently use such mechanisms, Murdoch University policy (ICT Security Standard 1.pdf, 10.5.4) requires default denial of privileges in the event of a malfunction. It's possible the vendor's product could be configured to provide accessibility features that would require overriding this default, creating an unmanaged access risk.	10.5.4 IT resources will be designed and configured by Information Technology Services to default to no access (denial of privileges to end-users) in the event of a malfunction.	Request further clarification from the vendor regarding their approach to accessibility and whether they can accommodate Murdoch University's requirement for default denial of privileges in case of malfunction. Obtain documentation demonstrating how their product handles potential accessibility needs without compromising security posture.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
THRD-05	Third-Party Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provided no evidence to support their claim of having a process for managing their hardware supply chain. Murdoch University Policy 6.2 requires business owners to monitor and review external provider's services. Without supporting documentation or demonstrable processes, the policy requirement is not met.	6.2. Business owners must monitor and review external provider's services at planned intervals to ensure appropriate security controls are implemented and maintained.	Request detailed information regarding the vendor's hardware supply chain management process, including export licensing procedures, compliance certifications, and evidence of ongoing monitoring.
APPL-02	Application Security	GAP	PARTIAL	PARTIAL	HIGH	4	3	CONTEXT A requires all individuals developing or administering applications handling University data to prominently display a 'Murdoch University' banner and validate input. The vendor did not provide evidence of WAF implementation beyond simply stating they use one. This does not address the requirement for application-level security controls like banner displays and input validation, which are critical for protecting University data.	11.1.1 Prominently display a 'Murdoch University' banner to the screen or interface in use by the application; 11.1.2 Ensure applications validate input properly and restrictively,	Request detailed documentation from the vendor outlining their WAF configuration, including rulesets used, logging practices, and how it enforces banner display requirements and input validation. Verify that the WAF is actively monitoring and blocking common web application attacks.
APPL-03	Application Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		7.4 Information Technology Services run vulnerability scans and conduct security assessments of University systems on a regular basis.	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
APPL-05	Application Security	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor provides no evidence to support their claim of separation of duties. Murdoch University policy (ICT Security Standard 1.pdf) requires this and mandates specific mechanisms like User Account Control or sudo with standard accounts. The lack of evidence raises concerns about the actual implementation.		Request detailed documentation outlining the implemented separation of duties, including specific controls and configurations. Verify these controls through independent audit if possible.
APPL-06	Application Security	PARTIAL	PARTIAL	PARTIAL	HIGH	4	3	While the vendor claims to perform static analysis/testing, no evidence was provided to corroborate this claim. Murdoch University policy (ICT Security Standard 1.pdf) requires documented peer reviews and quarterly security tests of applications. The vendor's response lacks detail regarding the specific tools used, frequency of testing, and documentation of these activities.	11.1.10 Conduct code-level security reviews with professionally trained peers for all new or significantly modified applications including	Request detailed information about the static analysis/testing process, including tool names, configuration settings, test coverage, and documented results. Require evidence of peer review processes.
APPL-07	Application Security	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor did not provide evidence to corroborate their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires documentation of actions taken for new or significantly modified applications and mandates quarterly security tests in addition to required application testing. Without supporting evidence, it's impossible to assess whether the vendor's processes meet these requirements.	11.1.11 Conduct quarterly security tests of applications in addition to application testing that is identified as required by Information Technology Services	Request detailed information regarding their software testing methodologies, including types of tests performed (dynamic/static), frequency, and documented results. Require evidence of adherence to Murdoch University's quarterly security test requirement.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
APPL-09	Application Security	PARTIAL	PARTIAL	PARTIAL	MINOR	3	2	The vendor provides no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires applications to validate input restrictively and execute proper error handling that does not reveal system information. Without supporting documentation or demonstrable implementation, we cannot confirm compliance.	11.1.2 Ensure applications validate input properly and restrictively, 11.1.3 Ensure applications execute proper error handling so that errors will not provide detailed system information, deny service, impair security mechanisms, or crash a University system	Request detailed technical specifications and examples of data validation mechanisms and error message formats from the vendor. Require evidence of testing these controls.
APPL-10	Application Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provided no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf, 1.9.1 & 1.9.2) requires explicit permission from Information Technology Services for auto-execute programs and assistance for installation. The vendor's 'Yes' response is insufficient without demonstrable procedures or controls.	1.9.1; 1.9.2	Request detailed documentation of the vendor's software supply chain management process, including specific controls implemented to ensure security and compliance with Murdoch University policies.
APPL-11	Application Security	PARTIAL	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor claims training but provides no evidence to support this claim. Murdoch University policy (Policy 11.1.1) mandates that all individuals involved in developing or administering applications handling University data must undergo code-level security reviews with professionally trained peers. Without verification of the training, we cannot confirm compliance.	Policy 11.1.1	Request supporting documentation demonstrating the scope and content of the developers' secure coding training program. This should include details on the training duration, topics covered, and the qualifications of the trainers.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
APPL-1 2	Application Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires code-level security reviews with professionally trained peers for all new or significantly modified applications including those that affect the collection, use, and/or display of confidential data. Without supporting documentation, we cannot assess compliance.	11.1.10 Conduct code-level security reviews with professionally trained peers for all new or significantly modified applications including those that affect the collection, use, and/or display of confidential data and document the actions that were taken;	Request detailed evidence of secure coding practices employed, including peer review processes and specific tools utilized. This should include documented code reviews and adherence to Murdoch University's requirements outlined in ICT Security Standard 1.pdf.
APPL-1 4	Application Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor claims a policy is in place but did not provide evidence to corroborate this. Murdoch University requires detailed documentation of the policy and procedures for granting administrator access, including review processes as outlined in ICT Security Standard 1.pdf (Policy 4). The response lacks specifics on how authorisation is checked and granted.	11.1.16 Document clear rules and processes for checking and granting authorisations; 11.1.17 On a quarterly basis, review and adjust/remove all authorisations/access for individuals who have left the university, transferred to another school or organisational unit, or assumed	Request vendor to provide documented proof of their policy or procedure, detailing the process for obtaining administrator access, including frequency of reviews and removal procedures.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-03	Access Control	GAP	PARTIAL	PARTIAL	EXTREME	5	3	The vendor provides no evidence to support their claim. Murdoch University policy (Policy 2 and Policy 3) requires password complexity and monitoring, but the vendor has not demonstrated this capability. While they state they *can* enforce it, we cannot verify this without supporting documentation.	2.6. All IT system's passwords must comply with the University's Password Policy. 2.4. University IT systems must be monitored and use effective malicious software management systems as described in the ICT Security Standard.	Request detailed information regarding the vendor's implementation of password/passphrase complexity enforcement mechanisms, including logging and auditing capabilities. Require evidence of successful testing.
AAAI-04	Access Control	GAP	PARTIAL	PARTIAL	EXTREME	5	3	The vendor did not provide evidence to corroborate their claim of password complexity or length limitations. Murdoch University policy (Policy 2 & Policy 3) mandates password policies and MFA requirements. Without supporting documentation, we cannot confirm compliance.	2.6. All IT system's passwords must comply with the University's Password Policy. 2.7. All authentications must have Mutli Factor Authentication enabled unless it is not possible due to technical or procedural restrictions. All exceptions must be approved and registered by the IT Security team or delegate.	Request detailed information from the vendor regarding their specific password complexity rules (e.g., minimum length, character types), and evidence of MFA implementation.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-05	Access Control	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor claims implementation but provides no evidence. Murdoch University policy (Policy 4) requires default to no access after a five-minute inactivity and password-protected screensavers. Without verification of documented procedures and current implementation, we cannot confirm compliance.	4.3. All user data requests must require approvals as described in the ICT Security Standard i.e. Murdoch Data Access Request Process.	Request supporting documentation demonstrating the existence and current operation of the documented password/passphrase reset procedures. Obtain evidence of implementation (e.g., screenshots, logs).
AAAI-06	Access Control	COMPLIANT	NOT_ASSESSED	COMPLIANT	MEDIUM	4	2			
AAAI-07	Access Control	GAP	COMPLIANT	PARTIAL	MEDIUM	4	2	Vendor did not provide evidence to corroborate their claim. Policy 2 and 5 require strong authentication mechanisms including passphrases and MFA where possible. Without independent verification, we cannot confirm compliance.		Request vendor to provide documentation or testing results demonstrating the absence of hardcoded passwords/passphrases. Consider requiring a penetration test specifically targeting this area.
AAAI-08	Access Control	GAP	COMPLIANT	PARTIAL	HIGH	4	3	The vendor has not provided evidence to corroborate their claim. While they state they don't store passwords in plaintext, this assertion needs independent verification. Murdoch University policy (ICT Security Standard 1.pdf, Page 9) mandates overwriting information with three random data passes or degaussing/physical destruction of devices to ensure data security.	5.2.1 Overwriting information with a minimum of three random data passes; 5.2.2 Degaussing and rendering data stored on the device unreadable; or 5.2.3 Physical destruction of the device.	Request the vendor provide evidence of their password management practices, such as a SOC 2 report detailing their controls for protecting sensitive data at rest. Further investigation is required to confirm compliance.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-10	Access Control	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor's response references AWS services but does not provide specific details on how logging is implemented or integrated with a SIEM system as required by Murdoch University policy. The provided links are to documentation about log collection and CloudTrail integration, which doesn't fully address the requirement for comprehensive logging of security events.	8.1.1 8.1.2 8.2	Request detailed information regarding the logging implementation, including SIEM integration, log retention policies, and specific log types captured. Verify that logs are being correlated and monitored effectively.
AAAI-12	Access Control	PARTIAL	COMPLIANT	PARTIAL	HIGH	4	3	While the vendor states integration is supported, no evidence was provided to corroborate this claim. Murdoch University policy (Policy 2 & Policy 5) mandates MFA and authentication for IT resources. The vendor's response lacks specifics on *how* integration occurs or what systems are supported, leaving a potential gap in security posture.	Policy 2.7 (All authentications must have Mutli Factor Authentication unless it is not possible due to technical or procedural restrictions. All exceptions must be approved and registered by the IT Security team or delegate.) & Policy 5.5 (Network services must require authentication: proxy services, email (SMTP) relays, wireless access points, remote desktop, secure shell access (SSH), and printer administrative interfaces).	Request detailed documentation outlining the specific authentication and authorization systems the application integrates with, including protocols used and security controls implemented during integration.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-13	Access Control	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	Policy 10.4.1 states that IT resource owners must establish specific authorisation privileges for IT resource access with appropriate privileges. Policy 10.4.3 requires administrative access to be minimal and only available to individuals who have been authorised by Information Technology Services. The vendor's 'Yes' response doesn't demonstrate how they ensure this authorization process is robust or that administrative access is truly minimized, leaving the University exposed to potential misuse of privileges.	10.4.1, 10.4.3	Require the vendor to provide detailed documentation outlining their processes for managing attribute mappings and ensuring minimal administrative access. Specifically request evidence of user authorization controls and regular privilege reviews.
AAAI-14	Access Control	PARTIAL	COMPLIANT	PARTIAL	MINOR	3	2	While the vendor states support for directory integration, no evidence was provided to corroborate this claim. Murdoch University policy (Policy 11.1.4) requires applications processing data authenticate users through central authentication systems. The lack of supporting documentation makes it difficult to assess the extent and effectiveness of this integration.	11.1.4 Ensure applications processing data authenticate users through central authentication systems	Request detailed documentation from the vendor outlining their directory integration capabilities, including supported protocols and configurations. Verify these claims with a technical assessment if possible.
AAAI-15	Access Control	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor provides no evidence to support their claim of supporting SAML2, OIDC, CAS or other web SSO standards. Murdoch University policy (Policy 1 & Policy 6) mandates requiring authentication for network services including email relays and remote desktop access. Without demonstrable support for these standards, the solution does not meet this requirement.		Request detailed documentation outlining supported SSO protocols and configurations to verify vendor claims.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AAAI-16	Access Control	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	Policy 10.2.1 and Policy 4.5 require unique user identification (userid) assignment based on employment or enrollment. The vendor's 'Yes' response doesn't specify *how* this differentiation is achieved – it lacks detail regarding the mechanism for ensuring distinct identifiers beyond just email addresses. This leaves Murdoch University vulnerable to potential account overlap or misuse.	10.2.1	Request detailed documentation from the vendor outlining their implementation of user identifier differentiation, including processes for assigning unique IDs and preventing conflicts.
CHNG-01	Change Management	PARTIAL	COMPLIANT	PARTIAL	EXTREME	5	3	While the vendor claims to notify of major changes, no evidence is provided to support this assertion. Murdoch University policy (Policy 3) requires change approvals via a Change Advisory Board and Business Owners, which the vendor's response does not address.		Request supporting documentation demonstrating the vendor's change notification process and adherence to established governance procedures.
CHNG-02	Change Management	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor confirms support but provides no evidence. Murdoch University policy (ICT Security Standard 1.pdf, 10.4.5) mandates that modifications to production data require approval from the Change Advisory Board and Business Owners. The vendor's response doesn't address this requirement regarding formal change management processes.	10.4.5 Privileged users must not modify production data in an unauthorised manner. If modification to production data is required, it must be in line with the University's established policy and procedures.	Request detailed documentation outlining the process for client customizations, including evidence of approvals and adherence to Murdoch University's Change Management Guidelines (Policy 4).

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-03	Change Management	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor provides no evidence to support their claim of an implemented system configuration management process. Murdoch University policy (Policy 1 & Policy 2) requires documented disaster recovery plans and CMDB records for critical IT systems. Without supporting documentation or demonstrable implementation, we cannot assess compliance.	2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	Request detailed information regarding the vendor's system configuration management process, including specific procedures, tools used, and evidence of successful implementation (e.g., secure 'gold' images).
CHNG-06	Change Management	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	Vendor does not verify library and dependency support with changes, failing to meet Murdoch University's requirement for change management processes as outlined in Policy 1 and Policy 3. This poses a significant risk of using unsupported software which could lead to instability, security vulnerabilities, or operational disruptions.	11.1.14 In accordance with the ICT Security Policy authorised third parties, including Service Providers, providing software and/or receiving University data must enter into written agreements with Murdoch University to secure systems and data;	Require the vendor to detail their process for verifying library and dependency support prior to implementing changes. Implement monitoring to detect use of unsupported libraries.
CHNG-07	Change Management	PARTIAL	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor claims to have a policy and procedure but did not provide evidence to corroborate this claim. Murdoch University requires documented disaster recovery plans for critical IT systems (Policy 2) and records of all assets in the CMDB (Policy 1). Without supporting documentation, it's impossible to verify if the vendor's policy is adequately implemented or maintained.	2.3.1 Security Patches	Request detailed documentation of the vendor's patch management policy and procedure. Specifically request evidence of implementation, including schedules, testing procedures, and audit trails.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-08	Change Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim. Murdoch University requires documented policies and procedures for risk mitigation until patches are applied (Policy 1 & 2). The response is insufficient as it lacks supporting documentation.		Request detailed documentation of the vendor's policies and procedures related to patch management and risk mitigation before proceeding with further assessment.
CHNG-09	Change Management	COMPLIANT	COMPLIANT	COMPLIANT	MINOR	3	2			
CHNG-10	Change Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	CONTEXT A does not specify a requirement for defining the number of concurrent versions supported. The vendor's 'fully implemented solution support strategy' is undefined and lacks detail regarding version management practices. This leaves Murdoch University with uncertainty about the vendor's ability to maintain systems across multiple software versions, potentially leading to compatibility issues or security vulnerabilities.		Request further clarification from the vendor detailing their specific approach to managing concurrent software versions, including version lifecycle management, patching strategies, and rollback procedures.
CHNG-11	Change Management	PARTIAL	PARTIAL	PARTIAL	MINOR	3	2	The vendor confirms a release schedule exists but provides no details regarding the schedule's frequency or severity assessment process. Murdoch University requires timely patching based on risk mitigation (Policy 6.2.3). The vendor's response lacks sufficient detail to demonstrate compliance with this requirement.		Request further information about the vendor's release schedule, including criteria for prioritizing patches and the frequency of updates.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-12	Change Management	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	3	3	While the vendor claims to have a roadmap, no evidence was provided to corroborate this assertion. Murdoch University policy (Policy 4) requires IT and non-IT Application and System owners to grant auditors access for vulnerability assessments, which implicitly requires visibility into planned changes. The lack of supporting documentation raises concerns about the thoroughness of their planning process.		Request vendor to provide details regarding their technology roadmap, including specific timelines, planned enhancements, and bug fix schedules. Obtain evidence (e.g., a documented roadmap) to validate this claim.
CHNG-13	Change Management	PARTIAL	PARTIAL	PARTIAL	MEDIUM	3	3	While the vendor claims they can complete updates without institutional involvement, Murdoch University policy (Policy 6) requires exemptions for unpatchable software to be logged in the ITS Vulnerability Exemption Register. The vendor did not provide evidence of this process or a mechanism for logging such exemptions. This creates a potential risk as unpatched systems remain vulnerable.		Vendor should detail their process for managing and documenting unpatchable software, including how they ensure compliance with Policy 6's exemption requirements.
CHNG-14	Change Management	PARTIAL	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's response is affirmative but lacks detail regarding the specific methods used to ensure no impact. Policy 1 states changes require Change Advisory Board approval and Business Owner review. The lack of evidence corroborates this.		Request further details from the vendor on their change management processes, including documentation of approvals and monitoring procedures.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
CHNG-15	Change Management	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	3	3	The vendor confirms procedures exist but provides no evidence of documentation or authorization processes. Murdoch policy requires documented and approved emergency changes. Further investigation is needed to verify the existence and effectiveness of these procedures.	2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	Request detailed documentation of the emergency change procedure, including approval workflows and post-incident review processes.
CHNG-16	Change Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's claim of a 'systems management and configuration strategy' is vague. Murdoch University requires documented strategies encompassing servers, appliances, cloud services, applications, and mobile devices (company and employee owned) as outlined in Policy 1.2 and 1.3. The vendor has not provided evidence to support this assertion, leaving the risk unassessed.	1.2. 1.3	Request detailed documentation of the vendor's systems management and configuration strategy, including specific processes for each asset type (servers, appliances, cloud services, applications, mobile devices).
DATA-01	Data Security	GAP	COMPLIANT	PARTIAL	EXTREME	4	4	The vendor has not provided evidence to corroborate their claim. Murdoch University policy (ICT Security Standard 1.pdf, 4.4) explicitly prohibits creating or connecting VPN servers or termination points within the university network without IT Services permission, which could lead to data residing on publicly routable IPs if improperly configured. Lack of evidence necessitates a possible risk.	4.4	Require vendor to provide verifiable documentation (e.g., network diagrams, IP address allocation plans) demonstrating that their systems do not utilize publicly routable IP addresses.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-04	Data Security	GAP	NOT_ASSESSED	GAP	EXTREME	4	4	Vendor did not provide evidence to corroborate their claim. Murdoch University policy (ICT Security Standard 1.pdf, Section 6) references the ACSC Essential Eight Maturity Model which implicitly requires adherence to FIPS standards for cryptographic modules. Without supporting documentation, we cannot assess compliance.		Request vendor to provide detailed evidence of FIPS certification for all cryptographic modules used in their solution. This should include certificates and test reports.
DATA-07	Data Security	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	5	4	The vendor's response indicates that backups containing institutional data are leaving the data zone, which directly contradicts Policy 1: ICT Security Standard and Policy 5: ICT Security Standard regarding secure storage and controlled transfer of data. This poses a significant risk to data security.		Require the vendor to implement controls preventing unauthorized outbound transfers of backup data. Implement strict monitoring and auditing procedures for all data movement.
DATA-08	Data Security	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor has not provided evidence to corroborate their claim of secure storage. Murdoch University policy (ICT Security Standard 1.pdf) requires durable physical or electronic labels with contact information and mandates secure storage practices, including physical security measures like locked offices or appliance storage. The vendor's assertion alone is insufficient.	12.1.6 Have a durable physical or electronic label with contact information sufficient to facilitate an expedient return in the event that a lost device is found; 12.1.7 Be used and stored in a manner that deters theft e.g. stored out of plain site/locked away.	Request detailed documentation from the vendor outlining their specific security controls for media storage, including environmental protection measures, access controls, and monitoring procedures. Obtain evidence of compliance with Murdoch University's requirements.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-15	Data Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor claims to have a documented process but provides no evidence. Murdoch University requires adherence to the Digital Media Disposal Standard (Policy 1) and CMDB recording of assets (Policy 3). The vendor's response lacks specifics on data sanitization procedures, which is critical for compliance.		Request detailed documentation of the media handling process, including specific data sanitization methods employed, to ensure alignment with Murdoch University's requirements.
DATA-16	Data Security	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor provides no evidence to support their claim of adherence to DoD 5220.22-M and/or NIST SP 800-88. Murdoch University policy references the ACSC Essential Eight Maturity Model, but does not explicitly mandate compliance with these specific standards. Without supporting documentation or a demonstrable process aligned with these standards, we cannot assess compliance.		Request vendor to provide evidence of adherence to DoD 5220.22-M and/or NIST SP 800-88 through documented processes and controls. Investigate if the vendor's approach aligns with the ACSC Essential Eight Maturity Model.
DATA-18	Data Security	GAP	PARTIAL	PARTIAL	HIGH	3	4	The vendor provides no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires a documented strategy for securing remote workstations, specifically addressing physical security and access controls. The vendor's response lacks detail regarding how this strategy is implemented and maintained.		Request detailed documentation of the vendor's remote workstation security strategy, including specific controls related to physical security, access management, and data protection.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DATA-19	Data Security	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		1.3 Use of shared computing facilities is subject to conditions which are designed to maintain the facilities in good order and to generate academic and administrative environments that are productive, ethical, legal, secure and effective.	
DATA-23	Data Security	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor did not provide any evidence to support their claim of a cryptographic key management process. Murdoch University policy (ICT Security Policy 1.pdf) requires documented and regularly tested disaster recovery plans for critical IT systems, including the safeguarding of data. Without supporting documentation or demonstrable implementation, we cannot assess compliance.	2.13. Critical IT systems must have disaster recovery plans that are documented and regularly tested.	Request detailed documentation outlining the vendor's cryptographic key management process, including procedures for generation, exchange, storage, safeguards, use, vetting, and replacement. Require evidence of ongoing monitoring and maintenance.
DCTR-02	Data Center	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor did not provide the SOC 2 report as evidence. While Murdoch requires a SOC 2 Type 2 report (Policy 2), the vendor has not provided it for verification. This leaves the risk unassessed.		Request and review the SOC 2 Type 2 report to verify compliance with Murdoch University's requirements.
DCTR-04	Data Center	COMPLIANT	NOT_ASSESSED	COMPLIANT	MINOR	3	2			

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-05	Data Center	PARTIAL	COMPLIANT	PARTIAL	HIGH	4	3	The vendor confirms separation but provides no evidence. Murdoch policy (Policy 3 & 5) mandates physical barriers and restricted access to server rooms. Without supporting documentation, we cannot confirm full compliance.	Policy 3.6 (Access to computer/server rooms must be restricted to authorised staff only. Computer/server rooms must be locked, secured, and protected by electronic access control systems and surveillance systems.)	Request detailed documentation from the vendor demonstrating the physical barrier implementation, including diagrams and specifications.
DCTR-06	Data Center	PARTIAL	PARTIAL	PARTIAL	HIGH	4	3	The vendor's assertion of a physical barrier requires supporting evidence to confirm it fully encloses the device space and prevents unauthorized access. Murdoch University policy (ICT Security Standard 1.pdf) states that exemptions exist if physical access is restricted, but this exemption does not extend to network-facing services running on the device. Without verification, we cannot determine compliance.		Request vendor to provide evidence of the physical barrier's design and implementation, demonstrating full enclosure and prevention of unauthorized contact.
DCTR-07	Data Center	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	3	3	While the vendor claims geographic diversity, no supporting evidence was provided to corroborate this assertion. Murdoch University policy (Policy 1 & Policy 3) mandates connection requests and physical security requirements for data centers. Without verification of geographic separation, we cannot confirm compliance.		Request documentation demonstrating the geographic separation between primary and secondary data centers. This could include maps or diagrams.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-08	Data Center	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim of a high-availability environment. Murdoch University policy (ICT Security Policy 1.pdf, section 3.5) requires critical ITS systems to be powered by sources able to run operations in the event of a power failure and have the ability to trigger orderly system shutdown. Without supporting documentation or demonstrable capabilities, this control cannot be considered compliant.	3.5. Critical ITS systems must be powered by sources able to run operations in the event of a power failure and have the ability to trigger orderly system shutdown.	Request detailed information regarding the vendor's high-availability architecture, including redundancy measures, failover procedures, and uptime guarantees. Require evidence (e.g., service level agreements) demonstrating adherence to Murdoch University's requirements for critical systems.
DCTR-09	Data Center	PARTIAL	COMPLIANT	PARTIAL	HIGH	4	3	The vendor confirms redundant power but does not provide evidence to corroborate this claim. Murdoch University policy (Policy 5: ICT Security Policy 1.pdf) requires critical ITS systems must have disaster recovery plans that are documented and regularly tested, implying redundancy is a key component. Without supporting documentation, the alignment cannot be fully assessed.	2.14. ITS assets must be recorded in the Configuration Management Data Base (CMDB) for the purpose of identification, classification, criticality, audit, and classified in accordance with the Data Classification Policy.	Request vendor to provide evidence of redundant power infrastructure, such as diagrams or certifications.
DCTR-10	Data Center	GAP	PARTIAL	PARTIAL	EXTREME	4	4	The vendor provides no evidence to support their claim of testing redundant power strategies. Murdoch University Policy 3.5 requires critical ITS systems to be powered by sources able to run operations in the event of a power failure and have the ability to trigger orderly system shutdown. Without verification, this control is not met.	3.5	Request detailed documentation and evidence demonstrating the testing procedures for redundant power strategies. This should include frequency, scope, and results of these tests.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-11	Data Center	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	3	3		3.1. Computer/server rooms must be physically strong and reasonably free from risk of flooding, fire, vibration, dust and other natural threats.	
DCTR-12	Data Center	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	CONTEXT A does not specify a requirement for ISP redundancy. The vendor's claim is unverified and lacks supporting evidence. Without policy guidance, it's impossible to assess alignment.		Request detailed documentation from the vendor outlining their ISP redundancy strategy, including failover mechanisms and service level agreements (SLAs).
DCTR-13	Data Center	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	3	3	The vendor's claim requires verification through independent audit or documentation. Murdoch University policy (ICT Security Standard 3.2) mandates compliance with IT Network Infrastructure Standards for wireless network installations, which implicitly suggests a need for multiple entry points for redundancy and security. The lack of evidence makes it difficult to assess the true level of compliance.		Request supporting documentation from the vendor detailing the number and configuration of network provider entrances at each data center. Conduct an audit or require third-party verification to confirm adherence to Murdoch University's IT Network Infrastructure Standard.
DCTR-14	Data Center	GAP	GAP	GAP	HIGH	4	3	Murdoch University policy (Policy 2 and Policy 5) mandates MFA for all authentications unless technically restricted and approved. The vendor's response directly contradicts this requirement. Failure to implement MFA on administrative accounts significantly increases the risk of unauthorized access and data compromise.	2.7. All authentications must have Multi Factor Authentication enabled unless it is not possible due to technical or procedural restrictions. All exceptions must be approved and registered by the IT Security team or delegate.	Require the vendor to implement MFA for all administrative accounts immediately, providing detailed documentation of implementation steps and ongoing monitoring procedures.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
DCTR-15	Data Center	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf, Section 5.4) mandates recording and securing data storage disk replacements. Without verification of the hardening tools or images used, it's impossible to determine if this requirement is met.	5.4 Data storage disks replaced as part of a IT repair must: 5.4.1 Be returned to Information Technology Services; and 5.4.2 Have all information removed in accordance with Section 5.2 before disposal.	Request detailed documentation from the vendor outlining the specific cloud provider hardening tools utilized and evidence of their implementation. Verify these tools align with Murdoch University's security standards.
DCTR-16	Data Center	GAP	PARTIAL	PARTIAL	EXTREME	4	4	Murdoch University policy (Policy 3) mandates encrypting data streams and providing a secure data path to critical systems. The vendor's response indicates they lack access to encryption keys, directly contradicting this requirement. This creates a significant risk of unauthorized access and potential data breaches.	4.3.2 Encrypt the data stream and provide a secure data path to critical systems;	Require the vendor to provide detailed documentation outlining their key management practices and demonstrate how they ensure encryption key security without direct access.
FIDP-04	Firewall & IDS/IPS	GAP	PARTIAL	PARTIAL	HIGH	4	3	CONTEXT A (Policy 5) explicitly prohibits removal, disablement, or reconfiguration of anti-virus software implemented by Information Technology Services. The vendor's response indicates host-based intrusion detection is employed but does not provide evidence of this implementation or adherence to Murdoch University's policies regarding such systems. The lack of evidence raises concerns about potential gaps in security posture.	1.5, 1.6	Request detailed documentation and evidence demonstrating the vendor's host-based intrusion detection system, including configuration details and ongoing monitoring practices, to ensure alignment with Murdoch University's ICT Security Standards.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
FIDP-05	Firewall & IDS/IPS	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor has not provided evidence to corroborate their claim of providing audit logs. Murdoch University policy (Policy 1 & Policy 4) mandates logging for servers, network devices, and firewalls, requiring forwarding to a SIEM system. Without supporting documentation or confirmation of log availability and forwarding, the requirement is not met.		Request detailed evidence of audit log functionality, including log format, retention period, and how logs are forwarded to the University's SIEM system. Obtain proof of configuration and operational procedures for log management.
FIDP-08	Firewall & IDS/IPS	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	CONTEXT A requires host-based intrusion prevention to prevent malicious programs from infecting Murdoch University's IT networks. The vendor confirms implementation but provides no evidence of this. Murdoch University Standard 1.5 prohibits removal, disablement or reconfiguration of anti-virus software, which would include host-based intrusion prevention systems.		Request supporting documentation demonstrating the deployment and configuration of the host-based intrusion prevention system, including logs and configurations to verify compliance with Murdoch University's ICT Security Standard 1.5.
FIDP-09	Firewall & IDS/IPS	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim of employing next-generation persistent threat monitoring. Murdoch University Policy 1 requires regular vulnerability assessments and penetration testing using appropriate tools. Without supporting documentation or demonstrable implementation, the policy requirement is not met.	Page 3 of 6 2.12. Information Technology Services must undertake regular vulnerability assessments and periodic penetration testing across IT systems using appropriate tools.	Request detailed information regarding the specific NGPT technologies employed, including configuration details and evidence of effectiveness.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
FIDP-10	Firewall & IDS/IPS	PARTIAL	COMPLIANT	PARTIAL	HIGH	4	3	While the vendor claims to perform intrusion monitoring, no evidence was provided to corroborate this assertion. Murdoch University policy (ICT Security Standard 1.pdf) requires logging of all servers and mandates vulnerability scans and security assessments by IT Services. The vendor's response lacks detail on how this monitoring is conducted or documented, leaving a gap in demonstrating compliance.	8.1.1 8.1.2	Request detailed documentation outlining the intrusion monitoring processes, tools used, and associated logs maintained. Require evidence of regular vulnerability scanning and penetration testing as per Murdoch University policy.
PPPR-01	Policies, Processes & Procedures	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor confirms a patch management process but did not provide evidence to corroborate this claim. Murdoch University policy (Policy 2 & Policy 4) requires documented patch management processes and logging in the ITS Vulnerability Exemption Register. Without supporting documentation, we cannot confirm compliance.	2.3.1 Campus networked devices must only run software for which security patches are made available in a timely fashion. All currently available security patches must be applied on a schedule appropriate to the severity of the risk they mitigate. Software that cannot be patched requires an exemption from the Information Security team and be logged in the ITS Vulnerability Exemption Register.	Request the vendor to provide documentation demonstrating their patch management process, including details on patching schedules, exception handling, and verification procedures.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
PPPR-02	Policies, Processes & Procedures	GAP	GAP	INSUFFICIENT EVIDENCE	EXTREME	5	3	The vendor's negative response indicates a failure to meet Murdoch University's requirements outlined in Policies 1, 3 and 4 regarding user access management, data protection requests, and adherence to relevant policies. This poses a significant risk to the confidentiality, integrity, and availability of University information.	4.3. All user data requests must require approvals as described in the ICT Security Standard i.e. Murdoch Data Access Request Process.	Require the vendor to provide detailed documentation outlining their compliance measures with Murdoch's ICT Security Policy, Password Policy, Privacy Policy, and IT Conditions of Use Policy. Further investigation is needed to understand the root cause of this non-compliance.
PPPR-03	Policies, Processes & Procedures	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2			
PPPR-04	Policies, Processes & Procedures	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor's claim of accommodating encryption is not substantiated by provided evidence. Murdoch University policy (Policy 10.3.2 & 10.3.3) mandates encrypted authentication mechanisms for IT resources and requires specific controls like encryption for mobile devices. The vendor has not demonstrated compliance with these requirements.	10.3.2	Require the vendor to provide detailed documentation outlining their encryption methods, including standards used, key management practices, and evidence of implementation across relevant systems. Further investigation is needed to assess the robustness of their approach.
PPPR-06	Policies, Processes & Procedures	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	CONTEXT A does not explicitly mandate background checks. While recommended in some sections, there is no specific requirement outlined. The vendor's claim needs to be substantiated with evidence beyond a simple 'yes'. Murdoch University requires documented processes for employee screening.		Request supporting documentation demonstrating the process and scope of background screenings conducted by the vendor. Clarify whether this meets Murdoch University's requirements, which are not defined in the provided policies.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
PPPR-07	Policies, Processes & Procedures	PARTIAL	COMPLIANT	COMPLIANT	MINOR	3	2	While the vendor's response aligns with Murdoch University's requirement to ensure new employees are aware of and acknowledge policies (Policy 4.5 & 4.6), no evidence was provided to corroborate this practice. Further investigation is needed to confirm implementation.	Policy 4.5. User accounts must be removed or disabled when a user terminates their employment or ceases to require system access.	
PPPR-10	Policies, Processes & Procedures	PARTIAL	COMPLIANT	COMPLIANT	MINOR	3	2	While the vendor states compliance, Murdoch University's policy requires clarification of this in the contract. No supporting evidence was provided to corroborate this claim.	providers and the data contained within such equipment must be clarified in the contract with the service provider and include all documentation of security contacts and escalation procedures.	
PPPR-13	Policies, Processes & Procedures	PARTIAL	COMPLIANT	PARTIAL	MEDIUM	3	3	The vendor claims to have processes but provides no evidence. Murdoch University policy (Policy 10.4.4 & 10.4.5) requires regular review and modification of privileges assigned to users, including privileged accounts. Without supporting documentation or demonstrable adherence, the alignment is partial.	10.4.4 Assigned privileges to users must be reviewed on a regular basis, and modified or revoked upon a change of status at Murdoch University. 10.4.5 Privileged users must not modify production data in an unauthorised manner.	Request vendor provide documented processes and evidence of ongoing reviews and modifications to privileged account access lists.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
VULN-01	Vulnerability Management	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor provides no evidence to corroborate their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires logging of exemptions for unpatched software and mandates remediation. Without evidence, we cannot confirm compliance.		Request the vendor provide documentation or logs demonstrating vulnerability scanning with authenticated accounts and remediation activities. Specifically request details on patching processes.
VULN-05	Vulnerability Management	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor did not provide evidence to corroborate their claim of regular scanning. Murdoch University Policy 1 requires regular vulnerability assessments and periodic penetration testing using appropriate tools. Without supporting documentation, the alignment with policy is partial.	2.12. Information Technology Services must undertake regular vulnerability assessments and periodic penetration testing across IT systems using appropriate tools.	Request and review evidence demonstrating the frequency, scope, and methodology of the vendor's web application security scans.
OPEM-01	Operational & Emerging Tech	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	Murdoch University policy (ICT Security Standard 1.pdf) requires RBAC for system administrators to minimize privileges and ensure accountability. The vendor's lack of support directly contradicts this requirement. While the HECVAT framework considers a 'Yes' response as compliant, Murdoch's policy mandates implementation.		The vendor must implement RBAC or provide a detailed justification for why it cannot meet this critical security control.
OPEM-02	Operational & Emerging Tech	COMPLIANT	COMPLIANT	COMPLIANT	LOW	1	1		10.6 Remote Network Access	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
OPEM-03	Operational & Emerging Tech	GAP	NOT_ASSESSED	GAP	HIGH	4	3	The vendor's refusal to provide required architectural diagrams and data communication descriptions directly contradicts Murdoch University's policy requirements (ICT Security Standard 1.pdf) regarding system documentation and authorization processes (11.1.16). This significantly increases the risk of undetected vulnerabilities and potential security breaches.		Require the vendor to immediately provide detailed architectural diagrams and data communication descriptions, demonstrating compliance with Murdoch University's requirements.
OPEM-04	Operational & Emerging Tech	GAP	COMPLIANT	PARTIAL	MINOR	3	2	While the vendor's response aligns with Murdoch University's policy (Policy 1 & Policy 5), the lack of provided evidence makes it difficult to fully corroborate. The policy requires a mechanism for privilege escalation and running services under minimum necessary privileges, which the vendor confirms they do not require. However, without documentation or further clarification, we cannot definitively assess if this aligns with Murdoch's specific implementation.	2.2.1 Devices must be configured to "lock" or log out and require a user to re-authenticate if left unattended for more than twenty (20) minutes, except in the following cases:	Request detailed information from the vendor regarding their security practices related to remote management, including how they manage user access and privilege escalation, to ensure alignment with Murdoch University's policies.
OPEM-05	Operational & Emerging Tech	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	5	4	Vendor's lack of logging directly contradicts Murdoch University's policy requiring logging and time synchronization (Policy 2). This poses a significant risk to auditability and security monitoring. The 'Almost Certain' likelihood reflects the high probability of undetected unauthorized activity due to this deficiency.		Require vendor to implement comprehensive logging of all remote actions and changes, ensuring alignment with Murdoch University's NTP server synchronization requirements.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
OPEM-06	Operational & Emerging Tech	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	4	4	Vendor's response indicates a failure to comply with FERPA requirements for remote access. Murdoch University requires all data handling to be compliant (Policy 5). The vendor has not provided evidence to support compliance.		Require the vendor to provide detailed documentation and evidence of their FERPA compliance procedures before granting remote access.
OPEM-07	Operational & Emerging Tech	GAP	NOT_ASSESSED	GAP	MINOR	3	2	Murdoch University Standard (ICT Security Standard 1.pdf) requires systems not deployed by Information Technology Services to be approved and configured with standard anti-virus software, and that logging is enabled. The vendor's lack of SNMPv3 support directly contradicts this requirement as it prevents monitoring capabilities. No policy exists regarding SNMPv3 specifically.		Vendor must provide a solution for campus status monitoring via SNMPv3 or equivalent technology to meet Murdoch University's requirements.
OPEM-08	Operational & Emerging Tech	GAP	NOT_ASSESSED	INSUFFICIENT_EVIDENCE	MEDIUM	3	3	The vendor did not provide any information regarding monitoring for malicious activity. This is a critical control and the lack of response leaves Murdoch University exposed. Policy 1.13 requires reporting suspected incidents, and Policy 2.2 mandates appropriate access controls and authentication mechanisms which implicitly require monitoring.		Require the vendor to detail their monitoring capabilities for malicious activity. Obtain specific documentation outlining implemented safeguards.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
OPEM-09	Operational & Emerging Tech	GAP	NOT_ASSESSED	INSUFFICIENT_EVIDENCE	MINOR	3	2	The vendor failed to provide any information regarding the duration of their business operations. This is a critical piece of information for assessing risk and compliance, as it directly impacts the stability and reliability of the vendor's services. Murdoch University requires this detail to determine if they can adequately assess operational maturity.		Request immediate clarification from the vendor regarding their history in this area and supporting documentation.
OPEM-10	Operational & Emerging Tech	GAP	NOT_ASSESSED	INSUFFICIENT_EVIDENCE	MINOR	3	2	The policy (ICT Security Standard 1.pdf) does not explicitly require the vendor to have existing higher education customers. The vendor's response is relevant to Murdoch University's operational needs but isn't directly addressed by any stated policy. Without further information about the vendor's business model, it's impossible to assess the risk.		Request clarification from the vendor regarding their target market and how they will ensure data security for higher education institutions if engaged in future projects with Murdoch University.
AIGN-01	AI Governance	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor claims to have an AI risk model but provides no evidence to support this claim. Murdoch University policy (Policy 1: ICT Security Policy) requires regular vulnerability assessments and periodic penetration testing across IT systems using appropriate tools, including evaluating risks associated with AI solutions. Without supporting documentation or demonstrable process, we cannot confirm compliance.		Request detailed information regarding the vendor's AI risk model, including its scope, methodology, and documented outputs. Require evidence of ongoing monitoring and maintenance of this model.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIGN-02	AI Governance	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		10.5.4 IT resources will be designed and configured by Information Technology Services to default to no access (denial of privileges to end-users) in the event of a malfunction.	
AIGN-03	AI Governance	COMPLIANT	PARTIAL	COMPLIANT	MEDIUM	4	2	While the vendor claims completion of training, no evidence was provided to corroborate this. Murdoch University policy (Policy 10.4.4) requires assignment of privileges to users based on employment and review of those privileges regularly. Without supporting documentation, it's difficult to verify the scope or effectiveness of the training.	10.4.4 Assigned privileges to users must be reviewed on a regular basis	Request vendor provide evidence of staff training completion, such as certificates or records of attendance.
AIGN-04	AI Governance	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor provides no details about the AI features or how they align with Murdoch University's ICT Security Standards. Without evidence of capabilities and adherence to policies regarding automated updates, input validation, and restrictions on auto-execution programs, it is impossible to assess compliance.		Request detailed documentation outlining the AI features offered, including specific controls implemented for data validation, access control, and malicious software prevention as per Murdoch University's ICT Security Standards. Require evidence of automated updates and restricted input handling.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIGN-05	AI Governance	PARTIAL	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor claims support but provides no evidence. Murdoch University policy (ICT Security Standard 1.pdf) requires IT Services to design and configure resources with default 'no access' privileges and password-protected screensavers. The vendor's response lacks specifics on how business rules are implemented to achieve this, leaving the level of protection uncertain.	10.5.4 IT resources will be designed and configured by Information Technology Services to default to no access (denial of privileges to end-users) in the event of a malfunction.	Request detailed documentation outlining the specific business rules implemented by the solution to ensure data protection aligns with Murdoch University's security standards.
AIPL-01	AI Policy	GAP	NOT_ASSESSED	GAP	HIGH	4	3	The vendor provided no evidence to support their claim. Murdoch University policy (ICT Security Policy 1.pdf) requires demonstrable implementation and posting of AI risk management practices. Without supporting documentation, it's impossible to assess compliance.		Request detailed information regarding the specific policies, processes, procedures, and practices implemented by the vendor for managing AI risks. Require evidence of their implementation (e.g., documented training programs, risk assessment reports).
AIPL-02	AI Policy	PARTIAL	COMPLIANT	PARTIAL	HIGH	4	3	The vendor provides no evidence to support their claim. Murdoch University requires documented risk assessments and mitigation strategies as per Policy 2.12 and 2.13. While the vendor states they've identified risks, this lacks sufficient detail and supporting documentation for a full compliance assessment.	2.12. Information Technology Services must undertake regular vulnerability assessments and periodic penetration testing across IT systems using appropriate tools.	Request detailed documentation of the AI risk identification and measurement process from the vendor, including methodologies used, scope of analysis, and documented findings.
AIPL-03	AI Policy	PARTIAL	COMPLIANT	COMPLIANT	MEDIUM	4	2	While the vendor claims they can disable their AI features, no evidence is provided to corroborate this claim. Murdoch University policy (10.5.4) mandates default denial of privileges for IT resources in malfunction scenarios. Without verification, we cannot confirm timely disabling.	10.5.4 IT resources will be designed and configured by Information Technology Services to default to no access (denial of privileges to end-users) in the event of a malfunction.	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIPL-04	AI Policy	GAP	PARTIAL	PARTIAL	HIGH	4	3	CONTEXT A outlines requirements for device lockdown and re-authentication after inactivity. The vendor's response lacks specifics on the 'timely manner' of re-enablement, leaving a gap in how this aligns with Murdoch's security standards. There is no evidence provided to support their claim.		Request detailed information from the vendor regarding their process for re-enabling AI features after an incident, including SLAs and escalation procedures. This should align with Murdoch's requirements for rapid restoration of service following a disruption.
AIPL-05	AI Policy	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides a general statement of having processes but does not provide evidence or detail the nature of these processes. Murdoch University requires documented technical and procedural processes as per Policy 5: ICT Security Standard 1.pdf. The response lacks specifics regarding how potential negative impacts are addressed.		Request detailed documentation outlining the vendor's AI risk management processes, including specific procedures for identifying, assessing, and mitigating risks associated with AI systems.
AISC-01	AI Security	GAP	GAP	INSUFFICIENT_EVIDENCE	EXTREME	5	4	Murdoch University policy (Policy 1 & Policy 6) mandates that sensitive data must be removed before disposal and requires authorisation for access to restricted systems. The vendor's inability to remove data upon request directly contradicts these policies and poses a significant risk of unauthorized data exposure within the AI model. This represents a likely impact and a major concern.	6.1.5 Director, Information Technology Services will authorise release of information. 6.1.6 Written consent must be obtained from current staff who are the subject of the operational request.	The vendor needs to demonstrate a robust process for data removal from their AI models, aligned with Murdoch University's requirements for data handling and access control.
AISC-02	AI Security	COMPLIANT	COMPLIANT	COMPLIANT	LOW	2	1		11.1.2 Ensure applications validate input properly and restrictively, allowing only the type of input that is known to be correct.	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AISC-03	AI Security	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor did not provide evidence to corroborate their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires logging for servers, network devices and firewalls including user data, date and action taken. The vendor's response lacks specific details about the logging mechanism and its scope, leaving a significant gap in demonstrating compliance.		Request detailed documentation of the logging implementation, including log retention policies, security controls applied to the logs, and how the logs are integrated with the SIEM system as per Murdoch University policy.
AISC-04	AI Security	GAP	NOT_ASSESSED	INSUFFICIENT_EVIDENCE	MEDIUM	3	3	The vendor did not provide any information regarding user input validation. This directly contradicts Murdoch University's requirement to ensure applications validate input properly and restrictively (Policy 11.1.2). Without a response, the risk cannot be assessed.	11.1.2	Request detailed documentation from the vendor outlining their user input validation processes, including specific techniques employed.
AISC-05	AI Security	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	Murdoch University policy (ICT Security Policy 1.pdf) requires business owners to monitor and review external provider's services at planned intervals to ensure appropriate security controls are implemented and maintained (6.2). The vendor has not provided evidence of this ongoing monitoring or risk mitigation strategy, leaving Murdoch with no assurance that supply chain risks are being adequately addressed.		Require the vendor to provide detailed documentation outlining their supply chain risk management processes, including frequency of reviews, specific controls implemented, and evidence of effectiveness.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIML-01	AI/ML Data Separation	GAP	GAP	GAP	EXTREME	5	3	Vendor's response contradicts Murdoch University's policy requiring separation of ML training data from the solution. This poses a significant risk to data integrity and model bias, potentially leading to inaccurate predictions and compromised decision-making. The lack of evidence further exacerbates this concern.	10.4.5 Privileged users must not modify production data in an unauthorised manner. If modification to production data is required, it must be in line with the University's established policy and procedures.	Require vendor to implement a robust data separation strategy, including technical controls and documented processes, before proceeding with integration. Conduct further due diligence to assess the feasibility and effectiveness of their proposed solution.
AIML-02	AI/ML Data Separation	GAP	GAP	GAP	EXTREME	5	3	Vendor does not authenticate and verify ML model feedback, failing to meet Murdoch University's requirement for ensuring research obligations request a user account (i.e. MAIS other) from an authorised agent at the University. Policy 2 states this is required. The lack of authentication introduces significant risk regarding data integrity and potential misuse.	Policy 2: research obligation on behalf of Murdoch University must request a user account (i.e. MAIS other) from an authorised agent at the University.	Require vendor to implement robust authentication and verification mechanisms for ML model feedback, including detailed logging and audit trails.
AIML-03	AI/ML Data Separation	GAP	GAP	INSUFFICIENT EVIDENCE	EXTREME	5	4	The vendor's response directly contradicts Murdoch University's requirement to vet, validate, and verify ML training data (Policy 1: ICT Security Standard 1.pdf). This poses a significant risk of using biased or inaccurate data, leading to unreliable AI model outputs and potential negative consequences for decision-making.	11.1.16 Document clear rules and processes for checking and granting authorisations	Require the vendor to provide detailed documentation outlining their data vetting, validation, and verification processes before proceeding with further assessment.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIML-04	AI/ML Data Separation	GAP	GAP	INSUFFICIENT_EVIDENCE	HIGH	4	3	The vendor's response indicates a critical gap in data governance. Murdoch University policy (ICT Security Standard 1.pdf) requires quarterly review and adjustment of access for individuals who have left the university or changed roles, implying ongoing monitoring and auditing of data usage. The lack of monitoring and auditing poses a significant risk to data integrity and security.		Require the vendor to implement a robust data monitoring and audit program for their ML training data, aligned with Murdoch University's requirements for access controls and data classification.
AIML-05	AI/ML Data Separation	GAP	GAP	GAP	HIGH	4	3	The vendor's response directly contradicts Murdoch University's policy (Policy 10.4.3 and 10.4.5) which mandates that IT resources must be adjusted accordingly and privileged users must not modify production data in an unauthorized manner. Without demonstrable controls to restrict access based on business need, the risk of inappropriate data usage is likely.	10.4.3 Administrative access to IT resources should be minimal and only available to individuals who have been authorised by Information Technology Services. 10.4.5 Privileged users must not modify production data in an unauthorised manner.	Require the vendor to provide detailed documentation outlining their data access control mechanisms and demonstrate compliance with Murdoch University's policy requirements regarding limiting access to sensitive training data.
AIML-06	AI/ML Data Separation	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor has not implemented adversarial training or other model defense mechanisms. Murdoch University policy (ICT Security Standard 1.pdf) mandates an effective malicious software management system to minimise the risk of malicious software throughout the University; however, this standard does not specifically address ML-specific defenses like adversarial training. Without evidence of such measures, there is a potential risk that models are vulnerable to manipulation.		Require vendor to detail their approach to mitigating risks associated with adversarial attacks on ML models and provide supporting documentation.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AIML-07	AI/ML Data Separation	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	CONTEXT A does not contain a specific policy requirement for documenting and logging ML model inputs and outputs. Therefore, we cannot assess alignment with Murdoch University's internal policies. The vendor's claim is insufficient without supporting evidence or reference to relevant policy.		Request detailed documentation of the ML model's input and output logs, including a description of the data sources and transformations performed. Obtain evidence that this documentation is maintained and accessible.
AIML-08	AI/ML Data Separation	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	Murdoch University policy (ICT Security Standard 1.pdf, 10.4.5) requires privileged users to not modify production data in an unauthorized manner and mandates use of tracking and recovery software for lost or stolen resources. Watermarking training data is a critical control to prevent unauthorized modification and ensure data integrity. The vendor's lack of watermarking practices does not meet this requirement.		Require the vendor to implement a robust watermarking solution for all ML training data to mitigate the risk of unauthorized modifications.
AILM-01	LLM Privileges	COMPLIANT	COMPLIANT	COMPLIANT	MEDIUM	4	2		mechanism to escalate privileges (e.g. via User Account Control or via sudo) with a standard account is acceptable to meet this requirement.	

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AILM-03	LLM Privileges	GAP	PARTIAL	PARTIAL	EXTREME	5	3	Policy 1 and Policy 4 require that auto execution programs from external drives are prohibited. The vendor's response indicates human intervention is required for LLM features/plugins, which doesn't directly address the prohibition of automated external drive execution but implies a level of control that could be interpreted as mitigating risk associated with unauthorized automation. The lack of evidence corroborates this claim.		Request further clarification from the vendor on the specific mechanisms employed to ensure human oversight and prevent unintended automated actions related to their LLM features/plugins. Specifically, request documentation detailing how they manage potential risks associated with automated execution.
AILM-04	LLM Privileges	GAP	PARTIAL	PARTIAL	HIGH	4	3	The vendor provides no evidence to support their claim. Murdoch University policy (ICT Security Standard 1.pdf) requires mechanisms to escalate privileges and network services must run under accounts with minimum necessary privileges. Without supporting documentation or demonstrable controls, we cannot assess compliance.	11.1.2 Ensure applications validate input properly and restrictively, allowing only the type of input that is known to be correct.	Request detailed information regarding the vendor's implementation of this control, including specific technical controls and evidence of their effectiveness.
AILM-05	LLM Privileges	GAP	PARTIAL	PARTIAL	MEDIUM	3	3	The vendor provides no evidence to support their claim of limiting LLM resource use. Murdoch University policy (ICT Security Standard 1.pdf) requires the principle of 'least privilege' and minimal administrative access to IT resources, including network services. Without supporting documentation or a description of how this limitation is implemented, we cannot assess compliance.	10.4.3 Administrative access to IT resources should be minimal and only available to individuals who have been authorised by Information Technology Services.	The vendor must provide detailed evidence demonstrating how they limit LLM resource use per request, step, and action. This should include technical specifications and operational procedures.

ID	Section	HECVAT	Policy	Overall	RMF	L	I	Gap / Finding	Policy Clause	Recommendation
AILM-06	LLM Privileges	GAP	NOT_ASSESSED	GAP	MINOR	3	2	Murdoch University policy (ICT Security Policy 1.pdf, page 3) requires regular vulnerability assessments and periodic penetration testing across IT systems using appropriate tools. The vendor's lack of model tuning or validation mechanisms represents a potential security risk as it doesn't align with best practices for managing LLM risks. Since no evidence was provided to corroborate the claim, we cannot assess compliance.		The vendor should provide details on their LLM model validation and tuning processes to demonstrate adherence to Murdoch University's requirements.
AILM-07	LLM Privileges	GAP	NOT_ASSESSED	GAP	MEDIUM	3	3	The vendor has not provided any information regarding their practices for taint tracing or tracking of LLM plugin content. This directly contradicts the requirement to monitor and track all plugin content.		Require the vendor to provide detailed documentation outlining their process for taint tracing and tracking of LLM plugins, including specific tools and methodologies used.